

YLEUM: проверка перед платным выпуском

Публичная версия отчёта · 30.09.2026 16:36 МСК

Результат: готовность к выпуску не подтверждена.

В плане 67 обязательных сценариев. Подтверждённые отдельные шаги учитываются как частичные результаты. Непроверенные сценарии не считаются успешными.

Полный пункт	Количество
Подтверждён полностью	0
Частично проверен	11
Заблокирован	9
Не выполнен	47

Выполненные отдельные шаги

- Два синтетических владельца создали отдельные проекты; проверены взаимные отказы в доступе к редактору через интерфейс.
- После отзыва текущей сессии приватный редактор требует повторного входа; обновление страницы доступ не возвращает.
- В одном dev-preview проверены создание, чтение, изменение и сохранение заметок после обновления, отказ пустому заголовку, Unicode и отмена несохранённого изменения.
- Одна генерация завершилась рабочим превью. Два других запуска завершились отказом; успешное восстановление и публикация ещё не подтверждены.

Проверки исходников

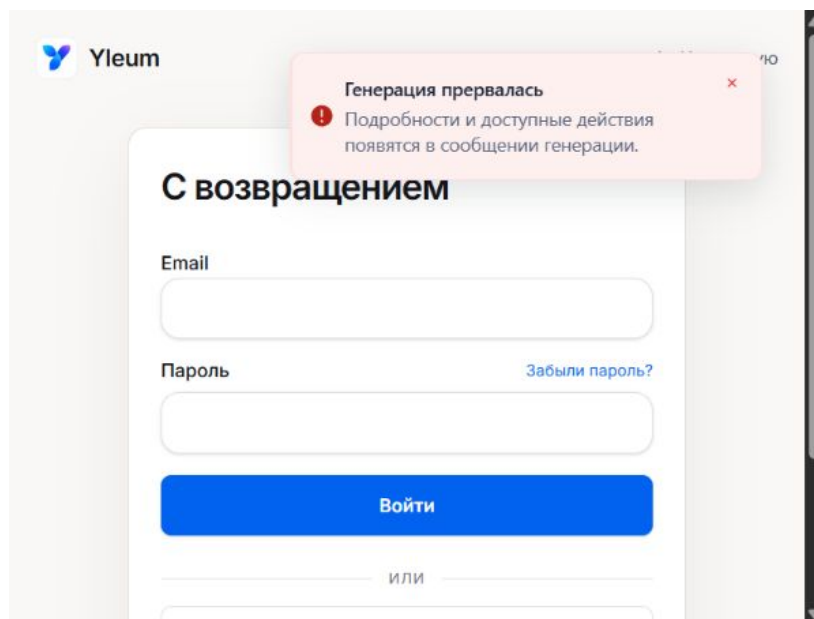
Для изменения общего срока генерации выполнены 74 локальные проверки. CI для c97bb530 выявил два падения тестов API. После разбора причин исправлены два тестовых сценария и отправлена ревизия 613c90f2; новый CI выполняется. Веб, gateway, orchestrator, Compose policy и сборка образов нового прогона прошли; итог API ещё ожидается. Изменение в production не выложено.

Черновой PR №44 · Повторный CI для 613c90f2

Этот файл не содержит доступов, адресов серверов, прямых ссылок на тестовые проекты и подробных закрытых доказательств безопасности. Полный отчёт и оригиналы хранятся локально.

Безопасные визуальные доказательства

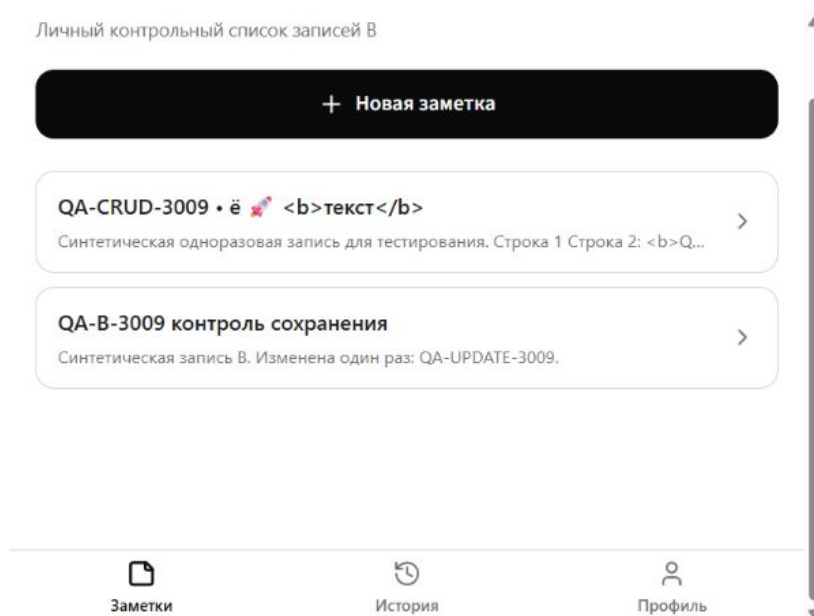
После отзыва сессии открыт вход



Результат интерфейса; повтор старого токена через приватный API отдельно не проверен.

SHA256 изображения: 91ccfcff146e2b59ff9e2354104a1ab6263426b0bdfcb3d27244b909e4b0a6d4

Синтетические заметки в dev-preview



Unicode и буквальный HTML отображаются в контрольной записи. Этот пример не доказывает полную защиту от XSS или изоляцию реальных пользователей MAX.

SHA256 изображения: 75d00ba4cfe1a3547fda7782d9cad49c1c28dad241a9b95a196d11e4422f3423

Короткий список для ручной приёмки

1. Вход и выход: регистрация, повторный вход, восстановление доступа — всё работает; после выхода закрытые страницы недоступны.
2. Чужие проекты: аккаунт А не открывает проект, файлы и данные аккаунта В, даже по прямой ссылке.
3. Права внутри приложения: обычный пользователь не видит чужие записи и не выполняет действия администратора.
4. Создание: создать проект → сгенерировать → проверить предпросмотр → опубликовать → открыть с другого устройства.
5. Данные: создать, изменить и удалить записи; загрузить файл; обновить страницу — результат сохраняется.
6. Обновление: изменить приложение и опубликовать заново — ранее созданные записи, пользователи и файлы сохраняются.
7. Повторные действия: дважды нажать сохранение, генерацию, публикацию и оплату — нет дублей и двойного списания.
8. Оплата: успешная оплата включает правильный тариф; отменённая и неуспешная не включают его.
9. Подписка: проверить продление, отмену, окончание срока и возврат — доступ соответствует результату.
10. Потеря связи: оборвать интернет во время сохранения и публикации — после возвращения понятен результат, данные не потеряны.
11. Устройства: пройти основной сценарий на телефоне и компьютере; проверить формы, ошибки и навигацию.
12. Восстановление: вместе с разработчиком проверить восстановление резервной копии и откат с сохранением пользовательских данных.

Порядок работы: T01, T03, T04, T06, T09, T02, T08, T05, T07, T10, T11, T12, T13. Проверки защиты данных и восстановления выполняются на изолированных синтетических данных.

Версия и условия проверки

PARTIAL — только часть критерия; BLOCKED — отсутствует условие запуска; NOT_RUN — нет доказательства выполнения.

T01.1 · P1 · BLOCKED

Действие: Сопоставить исходники, сервер и работающие сервисы: проверяем именно утверждённую версию.

Ожидание: Исходники, сервер и сервисы соответствуют утверждённой карте релиза.

T01.2 · P1 · PARTIAL

Действие: Зафиксировать включённые способы входа, тарифы, платёжные сценарии и поддерживаемые приложения.

Ожидание: Способы входа, тарифы и поддерживаемые сценарии зафиксированы.

T01.3 · P1 · PARTIAL

Действие: Подготовить независимых владельцев A/B, проекты A/B, пользователей и администраторов приложений.

Ожидание: Независимые владельцы/проекты и две личности внутри каждого приложения готовы.

T01.4 · P1 · BLOCKED

Действие: До тестов определить допустимые задержки, нагрузку, время восстановления и объём допустимой потери данных.

Ожидание: Цели задержки, нагрузки, RTO и RPO согласованы до запуска испытаний.

Вход, сессии и восстановление доступа

PARTIAL — только часть критерия; BLOCKED — отсутствует условие запуска; NOT_RUN — нет доказательства выполнения.

T02.1 · P1 · PARTIAL

Действие: Проверить все включённые способы входа, выход, повторный запуск и восстановление доступа.

Ожидание: Все включённые способы входа и восстановления корректны.

T02.2 · P1 · NOT_RUN

Действие: Изменённые, просроченные и отозванные токены отклоняются; использованные ссылки восстановления не работают повторно.

Ожидание: Недействительные и повторные одноразовые токены не дают доступа.

T02.3 · P1 · PARTIAL

Действие: Проверить завершение сессий после выхода, смены пароля и отзыва доступа.

Ожидание: Старая сессия отклоняется страницами и серверным API.

T02.4 · P1 · NOT_RUN

Действие: Перебор паролей и кодов ограничивается; восстановление не позволяет захватить чужой аккаунт.

Ожидание: Перебор ограничен; восстановление не захватывает чужой аккаунт.

T02.5 · P1 · NOT_RUN

Действие: OAuth и вход через MAX, если включены: подмена параметров, повтор callback, истечение срока и связывание аккаунтов не обходят проверку личности.

Ожидание: Подмена, повтор и просрочка OAuth/MAX не обходят проверку личности.

Изоляция владельцев и проектов

PARTIAL — только часть критерия; BLOCKED — отсутствует условие запуска; NOT_RUN — нет доказательства выполнения.

T03.1 · P1 · PARTIAL

Действие: Подменять идентификаторы во всех операциях чтения, изменения, удаления и экспорта: А не получает доступ к В.

Ожидание: Чужие read/write/delete/export отклонены без раскрытия и изменения данных.

T03.2 · P1 · PARTIAL

Действие: Проверить отдельно файлы, БД, поиск, кеш, предпросмотры, временные ссылки и резервные копии.

Ожидание: Нет чужого доступа через файлы, поиск, кеш, ссылки, preview и backup.

T03.3 · P1 · NOT_RUN

Действие: Проверить отозванные права и роли: отказ действует сразу и на сервере.

Ожидание: Отзыв роли/прав немедленно применяется сервером.

T03.4 · P1 · PARTIAL

Действие: Удаление или сбой проекта А не затрагивает проект В.

Ожидание: Контрольные записи и работа проекта В не изменены.

Защита конечных пользователей приложений

PARTIAL — только часть критерия; BLOCKED — отсутствует условие запуска; NOT_RUN — нет доказательства выполнения.

T04.1 · P1 · NOT_RUN

Действие: Отдельно проверить вход и сессии внутри опубликованных приложений.

Ожидание: Сессии приложения привязаны к проверенной личности конечного пользователя.

T04.2 · P1 · NOT_RUN

Действие: Пользователь видит только разрешённые ему записи и файлы; подмена роли или ID не расширяет доступ.

Ожидание: Сервер ограничивает строки/файлы/действия по личности и роли.

T04.3 · P1 · NOT_RUN

Действие: Пользователи разных приложений изолированы, включая приложения одного владельца.

Ожидание: Данные из другого приложения недоступны даже у одного владельца.

T04.4 · P1 · NOT_RUN

Действие: Экспорт и удаление персональных данных охватывают нужного пользователя без выдачи чужих данных.

Ожидание: Экспорт/удаление затрагивает только нужного пользователя.

T04.5 · P1 · NOT_RUN

Действие: Новая генерация приложения не убирает ранее проверенные ограничения доступа.

Ожидание: Обновлённое приложение сохраняет проверенные ограничения доступа.

Генерация и публикация

PARTIAL — только часть критерия; BLOCKED — отсутствует условие запуска; NOT_RUN — нет доказательства выполнения.

T05.1 · P1 · PARTIAL

Действие: Проверить первое создание, повторную генерацию, предпросмотр и публикацию.

Ожидание: Создание, генерация, preview и публикация дают работающий результат.

T05.2 · P1 · PARTIAL

Действие: Ошибка сборки, отмена и тайм-аут дают понятный статус и возможность безопасного повтора.

Ожидание: Ошибка/отмена/таймаут имеют точный статус и безопасный повтор.

T05.3 · P1 · NOT_RUN

Действие: Предыдущая рабочая версия доступна до успешного переключения.

Ожидание: Рабочая версия доступна до успешного атомарного переключения.

T05.4 · P1 · NOT_RUN

Действие: Опубликованный результат соответствует выбранной версии.

Ожидание: Открывается именно выбранная опубликованная версия.

T05.5 · P1 · NOT_RUN

Действие: Повторная публикация не создаёт конфликтующие ресурсы; бесплатные и платные ограничения проверяются сервером.

Ожидание: Нет конфликтных ресурсов; тарифные ограничения проверяются сервером.

Запись и сохранность данных

PARTIAL — только часть критерия; BLOCKED — отсутствует условие запуска; NOT_RUN — нет доказательства выполнения.

T06.1 · P1 · PARTIAL

Действие: Проверить создание, чтение, изменение, удаление, файлы, связи и ограничения полей.

Ожидание: CRUD, файлы, связи и ограничения работают на синтетических данных.

T06.2 · P1 · NOT_RUN

Действие: Одновременное редактирование не приводит к незаметной потере изменений.

Ожидание: Конфликт редактирования обнаружен; нет скрытой потери.

T06.3 · P1 · NOT_RUN

Действие: Обрыв связи после записи не создаёт дубликат при повторе запроса.

Ожидание: Повтор после обрыва не создаёт дубль уже записанной операции.

T06.4 · P1 · NOT_RUN

Действие: Ошибка БД не показывает пользователю ложное «сохранено».

Ожидание: При неуспешной записи UI не сообщает ложный успех.

T06.5 · P1 · NOT_RUN

Действие: После обновления приложения сверить записи, идентификаторы, связи, файлы и права доступа.

Ожидание: Все контрольные записи, IDs, связи, файлы и права сохранены.

Одновременные операции

PARTIAL — только часть критерия; BLOCKED — отсутствует условие запуска; NOT_RUN — нет доказательства выполнения.

T07.1 · P1 · NOT_RUN

Действие: Запустить генерацию и публикацию дважды и из разных сессий.

Ожидание: Одна операция/списание при повторах и нескольких сессиях.

T07.2 · P1 · NOT_RUN

Действие: Проверить конфликт публикации, удаления, изменения тарифа и отката.

Ожидание: Конфликтные операции завершаются согласованно и безопасно.

T07.3 · P1 · NOT_RUN

Действие: Задержавшаяся старая задача не перезаписывает результат новой.

Ожидание: Устаревшая задача не изменяет результат новой.

T07.4 · P1 · NOT_RUN

Действие: Истечение блокировки и перезапуск исполнителя не создают двух владельцев операции.

Ожидание: Блокировки/fencing исключают двух действующих исполнителей.

T07.5 · P1 · NOT_RUN

Действие: Активная версия, статус операции и журнал публикации остаются согласованными.

Ожидание: Активная версия, состояние и публикационный журнал согласованы.

Платежи и подписки

PARTIAL — только часть критерия; BLOCKED — отсутствует условие запуска; NOT_RUN — нет доказательства выполнения.

Все семь сценариев ожидают подключённый тестовый платёжный магазин. Реальные списания не выполнялись.

T08.1 · P1 · BLOCKED

Действие: Проверить успех, отказ, отмену и зависший платёж: сумма, валюта, владелец, тариф и срок верны.

Ожидание: Сумма, валюта, владелец, тариф и срок соответствуют подтверждённому платежу.

T08.2 · P1 · BLOCKED

Действие: Возврат из платёжной страницы сам по себе не выдаёт платный доступ.

Ожидание: Возврат браузера не включает тариф без серверного подтверждения.

T08.3 · P1 · BLOCKED

Действие: Повторные запросы и уведомления провайдера не дают двойного списания или начисления.

Ожидание: Идемпотентность исключает двойное списание/начисление.

T08.4 · P1 · BLOCKED

Действие: Поддельные уведомления и несоответствие суммы/аккаунта отклоняются.

Ожидание: Поддельное или несогласованное событие не меняет баланс/доступ.

T08.5 · P1 · BLOCKED

Действие: Потерянные, задержанные и переставленные уведомления корректно обрабатываются; сверка с провайдером выявляет расхождения.

Ожидание: Потеря/задержка/порядок событий исправляются сверкой с провайдером.

T08.6 · P1 · BLOCKED

Действие: Проверить автопродление, отмену, неудачное продление, окончание доступа, смену тарифа и возврат.

Ожидание: Срок и доступ корректны при продлении, отмене, ошибке и возврате.

T08.7 · P1 · BLOCKED

Действие: При снижении тарифа данные сохраняются согласно утверждённой политике.

Ожидание: Данные сохраняются по утверждённой политике понижения тарифа.

Резервные копии, миграции и откат

PARTIAL — только часть критерия; BLOCKED — отсутствует условие запуска; NOT_RUN — нет доказательства выполнения.

T09.1 · P1 · NOT_RUN

Действие: Восстановить БД и файлы в отдельной среде; проверить содержимое и связи, а не только успешное завершение команды.

Ожидание: Восстановленные DB/файлы/связи сверены с контрольными данными.

T09.2 · P1 · NOT_RUN

Действие: Измерить фактическое время восстановления и потерю данных.

Ожидание: Измеренные время и потеря данных укладываются в утверждённые RTO/RPO.

T09.3 · P1 · NOT_RUN

Действие: Проверить доступность и защиту копий; повреждённая или неполная копия обнаруживается.

Ожидание: Ваксир доступен только разрешённым лицам; повреждение выявляется.

T09.4 · P1 · NOT_RUN

Действие: Отдельно проверить откат кода, совместимость схемы и восстановление бизнес-данных.

Ожидание: Код, схема и бизнес-данные восстанавливаются по отдельным процедурам.

T09.5 · P1 · NOT_RUN

Действие: Создать записи до и после обновления: откат приложения не должен молча удалить новые данные.

Ожидание: Откат не удаляет молча новые пользовательские данные.

T09.6 · P1 · NOT_RUN

Действие: Проверить ошибку миграции и тайм-аут после изменения схемы, включая безопасное продолжение восстановления.

Ожидание: После частичной миграции/таймаута восстановление безопасно воспроизводится.

Отказы и перезапуски

PARTIAL — только часть критерия; BLOCKED — отсутствует условие запуска; NOT_RUN — нет доказательства выполнения.

T10.1 · P1 · NOT_RUN

Действие: Перезапустить сервисы во время сохранения, генерации и публикации.

Ожидание: Перезапуск не теряет подтверждённые записи и не дублирует операции.

T10.2 · P1 · NOT_RUN

Действие: Имитировать недоступность БД, очереди, хранилища, AI и платёжного провайдера.

Ожидание: Зависимость недоступна: контролируемый отказ и безопасное восстановление.

T10.3 · P1 · NOT_RUN

Действие: Проверить заполнение диска, нехватку памяти и исчерпание соединений.

Ожидание: Исчерпание ресурсов обнаружено; нет повреждения данных.

T10.4 · P1 · NOT_RUN

Действие: Повторы ограничены; завершённая операция не выполняется заново.

Ожидание: Повторы ограничены; завершённая операция не исполняется снова.

T10.5 · P1 · NOT_RUN

Действие: После восстановления нет потерянных записей, вечных статусов «выполняется» и бесконечных очередей.

Ожидание: Нет потерянных записей, вечных статусов и бесконечной очереди.

Безопасность и исполнение сгенерированного кода

PARTIAL — только часть критерия; BLOCKED — отсутствует условие запуска; NOT_RUN — нет доказательства выполнения.

T11.1 · P1 · NOT_RUN

Действие: Проверить обход прав, XSS, CSRF, SQL-инъекции, SSRF и обход путей.

Ожидание: Проверенные payload не обходят права и не выполняют запрещённое действие.

T11.2 · P1 · NOT_RUN

Действие: Проверить опасные файлы, неверный тип, чрезмерный размер и архивы.

Ожидание: Опасный тип/размер/путь/архив отклонён без выполнения и утечки.

T11.3 · P1 · PARTIAL

Действие: Проверить HTTPS, cookies, CORS и отсутствие секретов в браузере, URL, логах и ошибках.

Ожидание: HTTPS/cookie/CORS корректны; секреты не раскрываются в каналах.

T11.4 · P1 · NOT_RUN

Действие: Сгенерированный код не получает доступ к инфраструктуре, секретам и соседним проектам.

Ожидание: Сгенерированный код изолирован от секретов, инфраструктуры и соседей.

T11.5 · P1 · NOT_RUN

Действие: Инструкции в пользовательских файлах и запросах к AI не позволяют выполнить запрещённые действия или вывести приватные данные.

Ожидание: Недоверенные инструкции не дают запрещённого действия/приватных данных.

T11.6 · P1 · NOT_RUN

Действие: Проверить зависимости и образы; опасные находки разобрать до выпуска.

Ожидание: Зависимости/образы проверены; опасные находки закрыты или обоснованы.

Нагрузка и длительная работа

PARTIAL — только часть критерия; BLOCKED — отсутствует условие запуска; NOT_RUN — нет доказательства выполнения.

T12.1 · P1 · NOT_RUN

Действие: Измерить задержки обычных запросов, генерации и публикации при ожидаемой нагрузке.

Ожидание: Измеренная задержка и ошибки соответствуют согласованной нагрузке.

T12.2 · P1 · NOT_RUN

Действие: Проверить всплеск выше ожидаемого пика: ограничения работают, система восстанавливается.

Ожидание: Защитные лимиты действуют; система восстанавливается после пика.

T12.3 · P1 · NOT_RUN

Действие: Тяжёлый проект не блокирует остальных клиентов.

Ожидание: Тяжёлый проект не лишает других клиентов доступного ресурса.

T12.4 · P1 · NOT_RUN

Действие: Провести минимум 24 часа непрерывной работы: память, соединения, диск и очередь не растут бесконтрольно.

Ожидание: Не менее 24 часов фактических измерений без неограниченного роста.

T12.5 · P1 · NOT_RUN

Действие: После снятия нагрузки показатели возвращаются к норме.

Ожидание: После снятия нагрузки ресурсы и очередь возвращаются к норме.

Мониторинг и выпуск

PARTIAL — только часть критерия; BLOCKED — отсутствует условие запуска; NOT_RUN — нет доказательства выполнения.

T13.1 · P1 · NOT_RUN

Действие: По идентификатору операции можно проследить платёж, генерацию, публикацию и ошибку.

Ожидание: Операция прослеживается сквозь платёж, генерацию, публикацию и ошибку.

T13.2 · P1 · NOT_RUN

Действие: Проверить доставку алертов о недоступности, зависших задачах, неуспешных копиях и заполнении диска.

Ожидание: Тестовый алерт достигает назначенного получателя и содержит полезные данные.

T13.3 · P1 · NOT_RUN

Действие: Провести репетицию инцидента и восстановления по инструкции.

Ожидание: Инцидент и восстановление воспроизводятся по инструкции.

T13.4 · P1 · NOT_RUN

Действие: После выкладки повторить короткие проверки входа, доступа, записи данных, публикации и оплаты.

Ожидание: Свежий production smoke соответствует утверждённому релизу.

T13.5 · P1 · NOT_RUN

Действие: Зафиксировать версию, результаты, известные ограничения и ответственного за выпуск.

Ожидание: Версия, результаты, ограничения и ответственный за выпуск зафиксированы.